# TREPATH 2.5 AUTONOMOUS SCOPE PROVENANCE, EVE, EVI

Authorized Assessment Scope (owasp.org (+13 authorized origins across 14 in-scope assets)) | TrePath 2.5 Autonomous Scope Provena

| | |
|---|---|
| **Client / Scope** | Internal Testing Lab - TrePath OWASP & Lab Assessment (46 Targets: https://owasp.org/projects/juice-shop +45) (owasp.org (+13 authorized origins across 14 in-scope assets)) |
| **Scan Execution & Signing Window** | Scan Completed: 2026-11-02 15:01:39 UTC \| Report Rendered & Signed: 2026-11-02 16:19:58 UTC (0s UTC Drift \| Scan #44 \| Profile: authorized_pentest) |
| **Assessment Engine & Build** | TrePath 2.5 Autonomous Scope Provenance, EVE, EvidenceCore & RTEX Engine (Build: TP25-BUILD-20261102-UNIFIED \| Commit: f9a1c34e8b2d) |
| **Document Classification** | CONFIDENTIAL - Executive, Technical & Cryptographic Deliverable |
| **T0 Baseline Calibrated Risk** | MEDIUM (4.1 / 10 \| 41.1 / 100 Calibrated Index: Confirmed Compromise=0.0 pts, Control Gaps=14.1 pts, Surface/Baseline=27.0 pts) |
| **T1 Post-Retest Verified Risk** | 4.1 / 10 (0 Executed Retests Recorded in RTEX Ledger \| Verified Risk Reduction: 0.0 / 10) |
| **Hypothetical SLA Forecast** | HYPOTHETICAL_PROJECTION (Unverified Until RTEX Closure): Target 2.1 / 10 (LOW) upon full RTEX closure |
| **Verified Compromise / Admin Auth Status** | 0 CONFIRMED_ADMIN_AUTH (No authenticated admin console access verified in this scan) + 0 IMPACT_VERIFIED Safe PoCs |
| **7-Stage Scope Reconciliation Funnel** | 46 Requested Target(s) -> 46 ROE Authorized -> 14 Resolved Host(s) -> 14 In-Scope Origin Asset(s) -> 0 Out-of-Scope Probed -> 376 HTTP Endpoints |
| **Port & Transport Discovery State** | Raw TCP Port Scan: 0 open ports (SKIPPED_BY_WEB_ONLY_PROFILE) \| Application Transport: 376 HTTP(S) endpoints reachable across 14 origin(s) |
| **Finding Reconciliation (6-Tier)** | 180 Raw Observations -> 17 Consolidated Security Findings + 85 Recon/Surface Items + 1 Sensor Health Event |
| **Calibrated Threat Intelligence (KEV)** | 0 Raw KEV Matches -> 0 Unique KEV CVEs \| 0 CVE_APPLICABILITY_CONFIRMED \| 0 CVE_CORRELATED (Banner Only) |
| **4-Metric Sensor Coverage & Gate** | **Gate: PASSED_WITH_EXPLICIT_EXCLUSIONS \| Installed: 100.0% (6/6) \| Operational: 83.3% (5/6) \| Execution: 66.7% (4/6) \| Applicable: 100.0% (4/4)** |
| **EvidenceCore Ed25519 & Consistency** | Consistency: 100.0% (5/5 Invariants) \| Ed25519 Signature: VERIFIED_AUTHENTIC (Manifest SHA-256: fc5b9642d6b726b2a46570c1...) |
| **Platform-Aware Remediation** | Multi-Origin Web & API Hardening Enforced across 14 In-Scope Asset(s) (HTTP Security Headers, TLS & Endpoint Access Controls) |
| **Pre-Render Quality Gate** | **PASSED (26/26 Acceptance Rules + AT-01..AT-10 + NG-01..NG-06 + Ed25519 Tamper Self-Test PASSED \| Score=41.1/100 (4.1/10))** |

**Prepared by Expedite Consults Ltd | Generated 2026-11-02 16:19:58 UTC | TREPATH 2.5 AUTONOMOUS SCOPE PROVENANCE, EVI**

# 1. Executive Summary & Proof-Driven Assessment Overview

This assessment was executed by TrePath 2.5 Autonomous Scope Provenance, EVE, EvidenceCore & RTEX Engine against 46 submitted target(s) reconciled to 14 authorized in-scope origin asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)) under the 'authorized_pentest' Rules of Engagement. TrePath 2.5 Autonomous Scope Provenance, EVE, EvidenceCore & RTEX Engine enforces immutable 9-field asset provenance, per-origin written authorization governance, effective HTTP header-policy evaluation, 4-track score separation, pre-execution sensor readiness gating, 5-stage attack-path progression, and verifiable RFC 8032 Ed25519 cryptographic signing.

## 1.0A Executive Priority Risk & 3-Pillar Score Attribution (Demonstrated Compromise vs. Control Hygiene)

| Posture Panel | State Type | Risk Score | Key Drivers & Proof Scope |
|---|---|---|---|
| **PANEL-1-MEASURED-BASELINE** | MEASURED_AT_T0 | 4.1 / 10 (MEDIUM) | 17 Consolidated Findings across 14 origin(s): Confirmed Compromise=0.0 pts \| Control Gaps=14.1 pts \| Surface/Baseline=27.0 pts. |
| **PANEL-2-MEASURED-POST-RETEST** | MEASURED_AT_T1 | 4.1 / 10 (0 Retests) | RTEX Ledger active (0 retests executed; Verified T1 Risk Reduction: 0.0 / 10). |
| **PANEL-3-HYPOTHETICAL-FORECAST** | HYPOTHETICAL_PROJECTION | 2.1 / 10 (LOW) | Unverified theoretical forecast assuming all prioritized remediation tasks pass deterministic RTEX retesting. |

## 1.0B Four-Metric Sensor Coverage Model (Installed vs. Operational vs. Execution vs. Applicable)

| Sensor Coverage Metric | Measured Coverage | Operational & Evidentiary Definition |
|---|---|---|
| **1. Installed Coverage** | 100.0% (6/6) | Sensors installed and registered in TrePath 2.5 Autonomous Scope Provenance, EVE, EvidenceCore & RTEX Engine (WebPulse, Nuclei, OWASP ZAP, Nmap 7.95, Safe PoC/EVE Adapters, OpenVAS GVM). |
| **2. Operational Coverage** | 83.3% (5/6) | Sensors online and healthy during execution window (OpenVAS GVM recorded as STANDBY_OFFLINE when daemon is not attached). |
| **3. Execution Coverage** | 66.7% (4/6) | Sensors that actively executed probes against in-scope targets (Safe PoC adapters execute only when applicable preconditions exist). |
| **4. Applicable Coverage** | 100.0% (4/4) | Percentage of target-applicable sensors that executed and produced sealed EvidenceCore telemetry. |

## 1.0C Mandatory Pre-Execution Sensor Readiness Gate & Unavailable Capability Impact

| Sensor Capability | Readiness State | Material Coverage Impact | Explicit Scope & Evidentiary Impact |
|---|---|---|---|
| **Safe PoC & EVE Validation Adapters** | HELD_BY_ROE_OR_PRECONDITION | NO (0%) | Active exploitation & post-exploitation adapters held by ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY boundary (requires writtenLAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION authorization). |
| **OpenVAS / Greenbone GVM** | STANDBY_OFFLINE | NO (0%) | Network-layer NVT infrastructure CVE checks (TCP/UDP non-HTTP services) were not executed via OpenVAS GVM; compensated on web origins by Nuclei CVE templates + Nmap NSE + WebPulse. |

| ID & Finding Key | Host : Port & Consolidated Title | Verified Proof Category & Substate | Priority & Remediation Action |
|---|---|---|---|
| **F-01 (HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_)** | owasp.org:443 (ASSET-00070) \| [owasp.org:443] Missing HTTP Security Header(s): Con | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Configure the specific missing HTTP response header(s) on origin https://owasp.org:443: Content |
| **F-02 (HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM)** | google-gruyere.appspot.com:443 (ASSET-00072) \| [google-gruyere.appspot.com:443] Missing HTTP Securi | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Configure the specific missing HTTP response header(s) on origin https://google-gruyere.appspot |

| ID & Finding Key | Host : Port & Consolidated Title | Verified Proof Category & Substate | Priority & Remediation Action |
|---|---|---|---|
| **F-03 (HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM)** | tryhackme.com:443 (ASSET-00076) \| [tryhackme.com:443] Missing HTTP Security Header(s): | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Configure the specific missing HTTP response header(s) on origin https://tryhackme.com:443: Con |
| **F-04 (HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO)** | www.hackinghub.io:443 (ASSET-00079) \| [www.hackinghub.io:443] Missing HTTP Security Header | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Configure the specific missing HTTP response header(s) on origin https://www.hackinghub.io:443: |
| **F-05 (HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM)** | pentest-ground.com:443 (ASSET-00080) \| [pentest-ground.com:443] Missing HTTP Security Heade | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Configure the specific missing HTTP response header(s) on origin https://pentest-ground.com:443 |
| **F-06 (HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG)** | genai.owasp.org:443 (ASSET-00081) \| [genai.owasp.org:443] Missing HTTP Security Header(s | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Priority 40.7/100 \| Configure the specific missing HTTP response header(s) on origin https://genai.owasp.org:443: C |

## 1.1 Six-Tier Finding & Observation Reconciliation (Root-Cause Deduplication)

| Reconciliation Tier | Count | Scope & Deduplication Rule |
|---|---|---|
| **Tier 1 - Raw Scanner Observations** | 180 | All raw Nmap, Nuclei, httpx, ZAP, and PoC probe records prior to origin-scoped root-cause grouping. |
| **Tier 2 - Unique Assets & Open Services** | 14 Asset(s) / 0 TCP Ports | 14 authorized in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)) with 0 open TCP ports and 376 HTTP endpoints. |
| **Tier 3 - Consolidated Security Findings** | 17 | Deduplicated by (effective_origin, port, service_family, root_cause_slug); consolidates repeated missing headers per origin. |
| **Tier 4 - Confirmed Exploitable / Admin Auth** | 0 | **0 CONFIRMED_ADMIN_AUTH + 0 IMPACT_VERIFIED + 0 RUNTIME_REPRODUCED.** |
| **Tier 5 - Impact-Verified Safe PoCs** | 0 | **0 IMPACT_VERIFIED Safe PoCs** |
| **Tier 6 - Recon & Scanner Health Telemetry** | 85 Recon / 1 Sensor | Port discovery telemetry and OPENVAS-SENSOR-STANDBY separated from target vulnerabilities. |

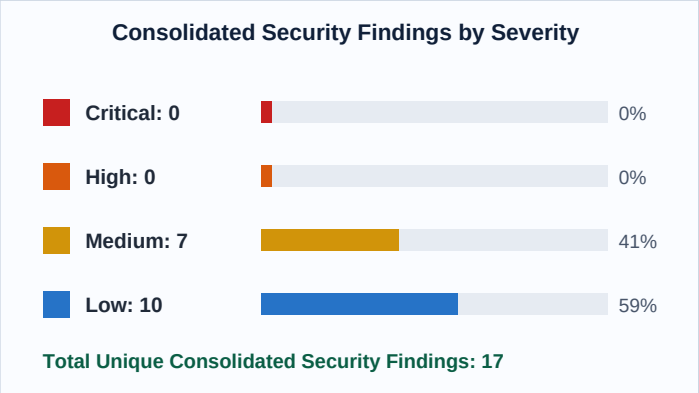
## 1.2 Seven-State Evidence Proof Classification & Granular PoC Substates

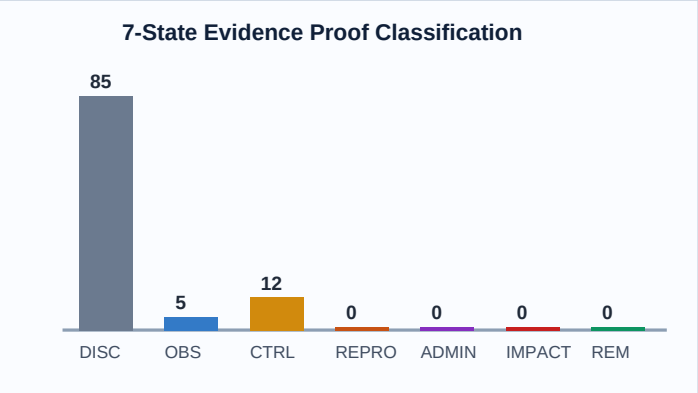
| Proof State | Count | Granular Substate & Evidentiary Meaning |
|---|---|---|
| **DISCOVERED** | 85 | Port/surface reachability observation only (CVSS 0.0; excluded from vulnerability count). |
| **OBSERVATION_CONFIRMED** | 5 | Service banner, protocol handshake, or cryptographic key observation confirmed. |
| **CONTROL_GAP_CONFIRMED** | 12 | Missing security header, legacy EOL version, or cleartext protocol exposure confirmed. |
| **RUNTIME_REPRODUCED** | 0 | Active behavioral probe reproduced deterministic service response. |
| **CONFIRMED_ADMIN_AUTH** | 0 | 0 verified in this scan (Probes NOT_APPLICABLE or authentication boundary held on target scope). |
| **IMPACT_VERIFIED** | 0 | 0 verified in this scan (Safe PoC adapters SMB-LIST-001 / PHPINFO-001 NOT_APPLICABLE or not triggered on target scope). |
| **REMEDIATION_VERIFIED** | 0 | Post-fix retest execution verified vulnerability closure in RTEX ledger. |

## 1.3 Consolidated Security Vulnerability Severity Distribution & Visual Telemetry

| Severity Level | Consolidated Count | CVSS v3.1 Band | Operational SLA Target |
|---|---|---|---|
| **CRITICAL** | 0 | 9.0 - 10.0 | Immediate containment (< 24 - 48 hours) |
| **HIGH** | 0 | 7.0 - 8.9 | Priority hardening (< 7 days) |
| **MEDIUM** | 7 | 4.0 - 6.9 | Scheduled remediation (< 30 days) |

| Severity Level | Consolidated Count | CVSS v3.1 Band | Operational SLA Target |
|---|---|---|---|
| **LOW** | 10 | 0.1 - 3.9 | Defense-in-depth maintenance (< 90 days) |




### 1.4 Explainable 7-Dimension Risk Score Decomposition (RiskEngine 2.5)

| Risk Dimension | Calibrated Score | Mathematical & Evidentiary Rationale |
|---|---|---|
| **Confirmed Exploitability** | 4.2 / 25.0 pts | Confirmed Exploitation: 0.0 pts (0 PoCs) \| Verified Control Gaps: 4.2 pts (12 CONTROL_GAP_CONFIRMED, 5 OBSERVATION_CONFIRMED). |
| **Verified Technical Impact** | 7.7 / 20.0 pts | Verified Compromise Impact: 0.0 pts (Admin Auth: No, SMB: No, PHPInfo: No) \| Control-Gap Severity Ceiling: 7.7 pts. |
| **Attack Surface Exposure** | 15.0 / 15.0 pts | 0 open TCP ports and 376 HTTP endpoints exposed across 14 in-scope origin(s). |
| **Applicable Threat Intelligence** | 0.2 / 15.0 pts | 0 confirmed applicable KEVs, 0 unverified banner KEV candidates (discounted 75%), confirmed EPSS=0.0 (raw banner max EPSS=0.08). |
| **Evidence-Backed Attack Paths** | 2.0 / 10.0 pts | 0 evidence-validated attack paths (0.0 pts when unverified), 1 correlated exposure clusters (2.0 pts). |
| **Asset Criticality** | 7.0 / 10.0 pts | Authorized assessment scope (14 in-scope asset(s), primary: owasp.org). |
| **Evidence Confidence** | 5.0 / 5.0 pts | 197 FIPS 180-4 SHA-256 sealed artifacts across 180 raw observations (Sensor Coverage - Installed: 100.0%, Operational: 83.3%, Execution: 66.7%, Applicable: 100.0%). |
| **TOTAL CALIBRATED RISK INDEX** | 41.1 / 100.0 pts (4.1 / 10) | Overall Rating: MEDIUM \| Applicable Max EPSS: 0.0 (Raw Banner EPSS: 0.08) |

## 2. Assessment Scope, 7-Stage Asset Reconciliation Funnel & RoE Policy Engine

### 2.0 Seven-Stage Scope & Asset Reconciliation Funnel (TP25-02)

| Funnel Stage | Count | Scope Provenance & Reconciliation Rationale |
|---|---|---|
| **1. Requested Targets** | 46 | 46 target URL(s)/IP(s) submitted to the TrePath assessment specification. |
| **2. ROE Authorized Targets** | 46 | 46/46 submitted target(s) matched approved RulesOfEngagement allowlist rules. |
| **3. Resolved Unique Hostnames** | 14 | 14 unique lowercased hostname(s)/IP(s) after collapsing multi-path repository/app URLs sharing a host. |
| **4. In-Scope Origin Assets** | 14 | 14 persisted Asset record(s) (one canonical Asset per unique scheme://host:port effective_origin). |
| **5. Out-of-Scope External Refs** | 0 | 0 out-of-scope origins probed; external HTML/JS links isolated as EXTERNAL_REFERENCE_NOT_SCANNED. |
| **6. Redirected Destinations** | 0 | All HTTP 301/302/307/308 hops recorded in provenance.redirect_chain; cross-origin redirects blocked. |
| **7. Discovered HTTP Endpoints** | 376 | 376 deduplicated canonical HTTP endpoints discovered across the 14 in-scope origin asset(s). |

## 2.0B Four-State Port & Application Transport Discovery Reconciliation

| Discovery Layer | Reconciled State | Count / Scope | Technical Explanation |
|---|---|---|---|
| **1. Raw TCP Port Scan** | SKIPPED_BY_WEB_ONLY_PROFILE | 0 Raw TCP Ports | Raw infrastructure TCP SYN/connect port scanning reported 0 open non-web infrastructure ports (skipped/filtered by edge CDN/WAF boundaries on multi-URL web scope), whereas HTTP/HTTPS application-layer probes verified active TCP/TLS transport on port(s) 443 across 14 in-scope origin(s) and 376 discovered HTTP endpoints. Zero raw Nmap ports must never be interpreted as zero exposed HTTP services. |
| **2. Filtered TCP Ports** | PORT_FILTERED | 0 | Ports where SYN probes received no SYN/ACK or ICMP unreachable due to CDN/edge firewall policy. |
| **3. Closed TCP Ports** | PORT_CLOSED | 0 | Ports responding with TCP RST. |
| **4. HTTP/TLS App Transport** | HTTP_HTTPS_TRANSPORT_REACHABLE | 376 Endpoints (14 Origins) | Application-layer HTTP/1.1 & HTTP/2 over TCP 443 verified across 14 origin(s). |

## 2.1 Authorized In-Scope Asset Inventory & Per-Origin Reconciliation

| Asset ID & Host | Scope Decision | Open TCP Ports | Asset Role & Provenance | Consolidated Findings | Verified PoC / Admin Auth |
|---|---|---|---|---|---|
| **ASSET-00070 (owasp.org)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 3 | 0 Verified |
| **ASSET-00071 (github.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 2 | 0 Verified |
| **ASSET-00072 (google-gruyere.appspot.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00073 (portswigger.net)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 2 | 0 Verified |
| **ASSET-00074 (pentesterlab.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00075 (www.hackthebox.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00076 (tryhackme.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00077 (www.hackthissite.org)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00078 (www.root-me.org)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 3 | 0 Verified |
| **ASSET-00079 (www.hackinghub.io)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00080 (pentest-ground.com)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00081 (genai.owasp.org)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |
| **ASSET-00082 (gandalf.lakera.ai)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 0 | 0 Verified |

| Asset ID & Host | Scope Decision | Open TCP Ports | Asset Role & Provenance | Consolidated Findings | Verified PoC / Admin Auth |
|---|---|---|---|---|---|
| **ASSET-00083 (vwad.owasp.org)** | IN_SCOPE | 0 TCP (HTTPS/443 & HTTP/80 Web Scope) | Authorized Web / API Origin (https_web_application \| HTTPS:443) | 1 | 0 Verified |

### 2.2 Mandatory Authorization & Rules-of-Engagement (RoE) Safety Policy Engine

| Rule ID | Policy Control | Enforcement Mechanism | Status |
|---|---|---|---|
| **ROE-01** | Authorized Scope Lock | All active probes restricted to 14 authorized in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)); crawled external links marked OUT_OF_SCOPE. | ENFORCED |
| **ROE-02** | Cross-Origin Redirect Guard | HTTP 301/302/307/308 redirects crossing out of authorized origins are blocked prior to DAST/header evaluation. | ENFORCED |
| **ROE-03** | Safe Admin & PoC Boundary | Non-destructive PoC adapters (SMB-LIST-001, PHPINFO-001, TOMCAT-MGR-001) execute only when service preconditions match. | ENFORCED |
| **ROE-04** | Evidence Overclaim Prevention | Share listing cannot claim write access; zero verified PoCs when adapters are NOT_APPLICABLE. | ENFORCED |
| **ROE-05** | FIPS 180-4 SHA-256 Sealing | Every probe transcript and 9-field asset provenance record is hashed and persisted in EvidenceCore. | ENFORCED |

## 3A. Consolidated Security Vulnerabilities & 4-Track Scoring (F-01 through F-17)

| ID | Origin Host:Port (Asset) | Severity & Vuln CVSS | 4-Track Scores (Ctrl / Recon / Exp) | Proof Category & Substate | Consolidated Title | Merged Raw Obs |
|---|---|---|---|---|---|---|
| **F-01** | owasp.org:443 (ASSET-00070) | MEDIUM \| Vuln CVSS: 5.5 | Ctrl:40.7 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (3 endpoints on origin) | 15 raw / 3 ep |
| **F-02** | google-gruyere.appspot.com:443 (ASSET-00072) | MEDIUM \| Vuln CVSS: 5.5 | Ctrl:40.7 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [google-gruyere.appspot.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) | 5 raw / 1 ep |
| **F-03** | tryhackme.com:443 (ASSET-00076) | MEDIUM \| Vuln CVSS: 5.5 | Ctrl:40.7 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [tryhackme.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) | 5 raw / 1 ep |
| **F-04** | www.hackinghub.io:443 (ASSET-00079) | MEDIUM \| Vuln CVSS: 5.5 | Ctrl:40.7 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [www.hackinghub.io:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, Permissions-Policy (1 endpoint on origin) | 3 raw / 1 ep |
| **F-05** | pentest-ground.com:443 (ASSET-00080) | MEDIUM \| Vuln CVSS: 5.5 | Ctrl:40.7 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [pentest-ground.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) | 5 raw / 1 ep |

| ID | Origin Host:Port (Asset) | Severity & Vuln CVSS | 4-Track Scores (Ctrl / Recon / Exp) | Proof Category & Substate | Consolidated Title | Merged Raw Obs |
|---|---|---|---|---|---|---|
| **F-06** | genai.owasp.org:443 (ASSET-00081) | MEDIUM \| Vuln CVSS: 5.5 | Ctrl:40.7 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [genai.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) | 5 raw / 1 ep |
| **F-07** | vwad.owasp.org:443 (ASSET-00083) | MEDIUM \| Vuln CVSS: 5.5 | Ctrl:40.7 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [vwad.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) | 5 raw / 1 ep |
| **F-08** | pentesterlab.com:443 (ASSET-00074) | LOW \| Vuln CVSS: 3.2 | Ctrl:24.6 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [pentesterlab.com:443] Missing HTTP Security Header(s): Content-Security-Policy, Permissions-Policy (1 endpoint on origin) | 2 raw / 1 ep |
| **F-09** | www.hackthebox.com:443 (ASSET-00075) | LOW \| Vuln CVSS: 3.2 | Ctrl:24.6 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [www.hackthebox.com:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin) | 3 raw / 1 ep |
| **F-10** | www.root-me.org:443 (ASSET-00078) | LOW \| Vuln CVSS: 3.2 | Ctrl:24.6 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [www.root-me.org:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin) | 3 raw / 1 ep |
| **F-11** | github.com:443 (ASSET-00071) | LOW \| Vuln CVSS: 3.2 | Ctrl:24.6 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [github.com:443] Missing HTTP Security Header(s): Permissions-Policy (30 endpoints on origin) | 30 raw / 30 ep |
| **F-12** | portswigger.net:443 (ASSET-00073) | LOW \| Vuln CVSS: 3.2 | Ctrl:24.6 \| Recon:15.0 \| Exp:20% | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | [portswigger.net:443] Missing HTTP Security Header(s): Referrer-Policy, Permissions-Policy (1 endpoint on origin) | 2 raw / 1 ep |
| **F-13** | www.hackthissite.org:443 (ASSET-00077) | LOW \| Vuln CVSS: N/A (Observation) | Ctrl:0.0 \| Recon:24.0 \| Exp:5% | OBSERVATION_CONFIRMED :: PRE_AUTH_FORM_CSRF_OBSERVED | [www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login | 2 raw / 1 ep |
| **F-14** | portswigger.net:443 (ASSET-00073) | LOW \| Vuln CVSS: N/A (Observation) | Ctrl:0.0 \| Recon:22.7 \| Exp:5% | OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED | [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://portswigger.net/web-security/dashboard | 1 raw / 1 ep |
| **F-15** | www.root-me.org:443 (ASSET-00078) | LOW \| Vuln CVSS: N/A (Observation) | Ctrl:0.0 \| Recon:22.7 \| Exp:5% | OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED | [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://www.root-me.org/admin | 1 raw / 1 ep |
| **F-16** | github.com:443 (ASSET-00071) | LOW \| Vuln CVSS: N/A (Observation) | Ctrl:0.0 \| Recon:17.8 \| Exp:5% | OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED | [github.com:443] API Rate-Limiting Telemetry Headers Absent (Enforcement Untested - OWASP API4:2023) (7 endpoints on origin) | 7 raw / 7 ep |

| ID | Origin Host:Port (Asset) | Severity & Vuln CVSS | 4-Track Scores (Ctrl / Recon / Exp) | Proof Category & Substate | Consolidated Title | Merged Raw Obs |
|---|---|---|---|---|---|---|
| F-17 | www.root-me.org:443 (ASSET-00078) | LOW \| Vuln CVSS: N/A (Observation) | Ctrl:0.0 \| Recon:15.0 \| Exp:5% | OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED | [API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Observed (/.within.website/x/cmd/anubis/api/honeypot/6dabeea5-bbe8-462f-8355-cdc93074954e/init) | 1 raw / 1 ep |

## 3A.1 Detailed Technical Findings & Cryptographic Evidence Cards

### F-01: [owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (3 endpoints on origin) [owasp.org:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00070 \| owasp.org:443 \| Effective Origin: https://owasp.org:443 (3 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://owasp.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 5.5 \| Control Priority: 40.7/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 15 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA, HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA, HTTP-HEADER-CONTENT_SECURITY_POLICY::T45_OWASP_ORG_WWW_PROJECT_MCP_TO, HTTP-HEADER-X_FRAME_OPTIONS::T45_OWASP_ORG_WWW_PROJECT_MCP_TO, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-REFERRER_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_) |
| **Technical Description** | [Target: https://owasp.org/www-project-juice-shop/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit. |
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://owasp.org:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=(). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1762/retest/execute on owasp.org:443 (ASSET-00070) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-01 / HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_):**

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_owasp_org_443
Immutable Provenance: Asset=ASSET-00070 | Effective Origin=https://owasp.org:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (15 across 3 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA,
HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA,
HTTP-HEADER-CONTENT_SECURITY_POLICY::T45_OWASP_ORG_WWW_PROJECT_MCP_TO,
HTTP-HEADER-X_FRAME_OPTIONS::T45_OWASP_ORG_WWW_PROJECT_MCP_TO,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-REFERRER_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: 821efeca57da276704479cf9a99ab575174e5aae7807b269686f0074388d37cb (Artifact
#1849 | Unique Forensic Transcript)
```

## F-02: [google-gruyere.appspot.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [google-gruyere.appspot.com:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00072 \| google-gruyere.appspot.com:443 \| Effective Origin: https://google-gruyere.appspot.com:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://google-gruyere.appspot.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 5.5 \| Control Priority: 40.7/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-REFERRER_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-PERMISSIONS_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM) |
| **Technical Description** | [Target: https://google-gruyere.appspot.com/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit. |
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://google-gruyere.appspot.com:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=(). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1796/retest/execute on google-gruyere.appspot.com:443 (ASSET-00072) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-02 / HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM):**

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_google_gruyere_appspot_com_443
Immutable Provenance: Asset=ASSET-00072 | Effective Origin=https://google-gruyere.appspot.com:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-REFERRER_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: e6c6055d4fed220aca5f4ef7f18417e27718f93f13df99502772ca88abc438e8 (Artifact
#1883 | Unique Forensic Transcript)
```

## F-03: [tryhackme.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [tryhackme.com:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00076 \| tryhackme.com:443 \| Effective Origin: https://tryhackme.com:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://tryhackme.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 5.5 \| Control Priority: 40.7/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-REFERRER_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-PERMISSIONS_POLICY::T38_TRYHACKME_COM) |
| **Technical Description** | [Target: https://tryhackme.com/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit. |
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://tryhackme.com:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=(). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1850/retest/execute on tryhackme.com:443 (ASSET-00076) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-03 / HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM):**

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_tryhackme_com_443
Immutable Provenance: Asset=ASSET-00076 | Effective Origin=https://tryhackme.com:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-REFERRER_POLICY::T38_TRYHACKME_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T38_TRYHACKME_COM
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: 5e565bb09cbd17d0aec0bb4de23387f7185bd9e325a546ed8620ef6f617fa04b (Artifact
#1937 | Unique Forensic Transcript)
```

## F-04: [www.hackinghub.io:443] Missing HTTP Security Header(s): Content-Security-Policy,

## X-Frame-Options, Permissions-Policy (1 endpoint on origin) [www.hackinghub.io:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00079 \| www.hackinghub.io:443 \| Effective Origin: https://www.hackinghub.io:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.hackinghub.io:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 5.5 \| Control Priority: 40.7/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 3 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO, HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO, HTTP-HEADER-PERMISSIONS_POLICY::T41_WWW_HACKINGHUB_IO) |
| **Technical Description** | [Target: https://www.hackinghub.io/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit. |
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://www.hackinghub.io:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; Permissions-Policy: geolocation=(), microphone=(), camera=(). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1859/retest/execute on www.hackinghub.io:443 (ASSET-00079) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-04 / HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO):**

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_www_hackinghub_io_443
Immutable Provenance: Asset=ASSET-00079 | Effective Origin=https://www.hackinghub.io:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (3 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO,
HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO,
HTTP-HEADER-PERMISSIONS_POLICY::T41_WWW_HACKINGHUB_IO
Header-Policy Evaluation: Present=['X-Content-Type-Options', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['Content-Security-Policy', 'X-Frame-Options',
'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: 26e23d176ec13047b39a86bff6c623e6fbf2cef89c76de8f1402b7f8237acb83 (Artifact
#1946 | Unique Forensic Transcript)
```

## F-05: [pentest-ground.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [pentest-ground.com:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00080 \| pentest-ground.com:443 \| Effective Origin: https://pentest-ground.com:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://pentest-ground.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 5.5 \| Control Priority: 40.7/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |

| | |
|---|---|
| **Deduplicated Observations** | 5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM, HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T42_PENTEST_GROUND_COM, HTTP-HEADER-REFERRER_POLICY::T42_PENTEST_GROUND_COM, HTTP-HEADER-PERMISSIONS_POLICY::T42_PENTEST_GROUND_COM) |
| **Technical Description** | [Target: https://pentest-ground.com/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit. |
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://pentest-ground.com:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=(). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1865/retest/execute on pentest-ground.com:443 (ASSET-00080) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-05 / HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM):**

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_pentest_ground_com_443
Immutable Provenance: Asset=ASSET-00080 | Effective Origin=https://pentest-ground.com:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM,
HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T42_PENTEST_GROUND_COM,
HTTP-HEADER-REFERRER_POLICY::T42_PENTEST_GROUND_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T42_PENTEST_GROUND_COM
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: fbfdb55046c1260acbaf4f8794f6071c53d53ff765848a1aa2afd1d015fc035b (Artifact
#1952 | Unique Forensic Transcript)
```

## F-06: [genai.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [genai.owasp.org:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00081 \| genai.owasp.org:443 \| Effective Origin: https://genai.owasp.org:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://genai.owasp.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 5.5 \| Control Priority: 40.7/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T43_GENAI_OWASP_ORG, HTTP-HEADER-REFERRER_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T43_GENAI_OWASP_ORG) |
| **Technical Description** | [Target: https://genai.owasp.org/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit. |
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://genai.owasp.org:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=(). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1871/retest/execute on genai.owasp.org:443 (ASSET-00081) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-06 / HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG):**

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_genai_owasp_org_443
Immutable Provenance: Asset=ASSET-00081 | Effective Origin=https://genai.owasp.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG,
HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T43_GENAI_OWASP_ORG,
HTTP-HEADER-REFERRER_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T43_GENAI_OWASP_ORG
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: c71617c2667cde4b7b173b44de8cc5bc0518a78e1c7bdc1a07986f5acae2e017 (Artifact
#1958 | Unique Forensic Transcript)
```

## F-07: [vwad.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [vwad.owasp.org:443 | MEDIUM | Vuln CVSS: 5.5 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00083 \| vwad.owasp.org:443 \| Effective Origin: https://vwad.owasp.org:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://vwad.owasp.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 5.5 \| Control Priority: 40.7/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-REFERRER_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T46_VWAD_OWASP_ORG) |
| **Technical Description** | [Target: https://vwad.owasp.org/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit. |
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://vwad.owasp.org:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=(). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1883/retest/execute on vwad.owasp.org:443 (ASSET-00083) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-07 / HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG):**

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_vwad_owasp_org_443
Immutable Provenance: Asset=ASSET-00083 | Effective Origin=https://vwad.owasp.org:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=5.5 | Control Priority=40.7 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG,
HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T46_VWAD_OWASP_ORG,
HTTP-HEADER-REFERRER_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T46_VWAD_OWASP_ORG
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: 0b04b271a07fe4aa5244b8dd64fc2178b9aa6611993ea78225c66721761db16f (Artifact
#1970 | Unique Forensic Transcript)
```

## F-08: [pentesterlab.com:443] Missing HTTP Security Header(s): Content-Security-Policy, Permissions-Policy (1 endpoint on origin) [pentesterlab.com:443 | LOW | Vuln CVSS: 3.2 |

## CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00074 \| pentesterlab.com:443 \| Effective Origin: https://pentesterlab.com:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://pentesterlab.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 3.2 \| Control Priority: 24.6/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 2 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM, HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM) |
| **Technical Description** | [Target: https://pentesterlab.com/] The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://pentesterlab.com:443: Content-Security-Policy: default-src 'self'; frame-ancestors 'none'; object-src 'none'; Permissions-Policy: geolocation=(), microphone=(), camera=(). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1840/retest/execute on pentesterlab.com:443 (ASSET-00074) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-08 / HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM):**

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_pentesterlab_com_443
Immutable Provenance: Asset=ASSET-00074 | Effective Origin=https://pentesterlab.com:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.2 | Control Priority=24.6 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (2 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM
Header-Policy Evaluation: Present=['X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['Content-Security-Policy', 'Permissions-Policy'] |
Compensating=[]
EvidenceCore SHA-256 Digest: 67e816e43c6a5a5056c75e788d1bbc5f7fcf116f70587763b5b85eae8c6ddf18 (Artifact
#1927 | Unique Forensic Transcript)
```

## F-09: [www.hackthebox.com:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin) [www.hackthebox.com:443 | LOW | Vuln CVSS: 3.2 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00075 \| www.hackthebox.com:443 \| Effective Origin: https://www.hackthebox.com:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.hackthebox.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 3.2 \| Control Priority: 24.6/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 3 raw scanner observations merged (HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM, HTTP-HEADER-PERMISSIONS_POLICY::T37_WWW_HACKTHEBOX_COM) |
| **Technical Description** | [Target: https://www.hackthebox.com/] The HTTP response did not include the x-content-type-options response header. This confirms a header observation only; it does not prove an exploit. |

| | |
|---|---|
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://www.hackthebox.com:443: X-Frame-Options: DENY (or verify CSP frame-ancestors 'self'); X-Content-Type-Options: nosniff; Permissions-Policy: geolocation=(), microphone=(), camera=(). Compensating Control Note: X-Frame-Options absence partially compensated by Content-Security-Policy presence (verify frame-ancestors directive). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1842/retest/execute on www.hackthebox.com:443 (ASSET-00075) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-09 / HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM):**

```
Finding Key: HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_www_hackthebox_com_443
Immutable Provenance: Asset=ASSET-00075 | Effective Origin=https://www.hackthebox.com:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.2 | Control Priority=24.6 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (3 across 1 endpoint(s)):
HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T37_WWW_HACKTHEBOX_COM
Header-Policy Evaluation: Present=['Content-Security-Policy', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['X-Frame-Options', 'X-Content-Type-Options',
'Permissions-Policy'] | Compensating=['X-Frame-Options absence partially compensated by
Content-Security-Policy presence (verify frame-ancestors directive)']
EvidenceCore SHA-256 Digest: edfd0ca6c4e3c5bb2dcb9da42fe69e05200bf14ebc3cf2b7ad693db90b1109a2 (Artifact
#1929 | Unique Forensic Transcript)
```

## F-10: [www.root-me.org:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin) [www.root-me.org:443 | LOW | Vuln CVSS: 3.2 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00078 | www.root-me.org:443 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.root-me.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 3.2 | Control Priority: 24.6/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 3 raw scanner observations merged (HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T40_WWW_ROOT_ME_ORG) |
| **Technical Description** | [Target: https://www.root-me.org/] The HTTP response did not include the x-content-type-options response header. This confirms a header observation only; it does not prove an exploit. |
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://www.root-me.org:443: X-Frame-Options: DENY (or verify CSP frame-ancestors 'self'); X-Content-Type-Options: nosniff; Permissions-Policy: geolocation=(), microphone=(), camera=(). Compensating Control Note: X-Frame-Options absence partially compensated by Content-Security-Policy presence (verify frame-ancestors directive). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1853/retest/execute on www.root-me.org:443 (ASSET-00078) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-10 / HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG):**

```
Finding Key: HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00078 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.2 | Control Priority=24.6 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (3 across 1 endpoint(s)):
HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG,
HTTP-HEADER-PERMISSIONS_POLICY::T40_WWW_ROOT_ME_ORG
Header-Policy Evaluation: Present=['Content-Security-Policy', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['X-Frame-Options', 'X-Content-Type-Options',
'Permissions-Policy'] | Compensating=['X-Frame-Options absence partially compensated by
Content-Security-Policy presence (verify frame-ancestors directive)']
EvidenceCore SHA-256 Digest: 1534fbe69e2048312e204c2a267a487354d34dea487d1c9ea503b6976dafd5f6 (Artifact
#1940 | Unique Forensic Transcript)
```

## F-11: [github.com:443] Missing HTTP Security Header(s): Permissions-Policy (30 endpoints on origin) [github.com:443 | LOW | Vuln CVSS: 3.2 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00071 \| github.com:443 \| Effective Origin: https://github.com:443 (30 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://github.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 3.2 \| Control Priority: 24.6/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 30 raw scanner observations merged (HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA, HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI, HTTP-HEADER-PERMISSIONS_POLICY::T6_GITHUB_COM_WEBPWNIZED_MUTILL, HTTP-HEADER-PERMISSIONS_POLICY::T7_GITHUB_COM_RAESENE_BWAPP, HTTP-HEADER-PERMISSIONS_POLICY::T8_GITHUB_COM_OWASP_SECURITYSHE, HTTP-HEADER-PERMISSIONS_POLICY::T9_GITHUB_COM_OWASP_NODEGOAT, HTTP-HEADER-PERMISSIONS_POLICY::T10_GITHUB_COM_ADEYOSEMANPUTRA_P, HTTP-HEADER-PERMISSIONS_POLICY::T11_GITHUB_COM_OWASP_RAILSGOAT) |
| **Technical Description** | [Target: https://github.com/OWASP/crAPI] The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://github.com:443: Permissions-Policy: geolocation=(), microphone=(), camera=(). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1772/retest/execute on github.com:443 (ASSET-00071) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-11 / HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI):**

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI | Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_github_com_443
Immutable Provenance: Asset=ASSET-00071 | Effective Origin=https://github.com:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.2 | Control Priority=24.6 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE | Merged Raw Observations (30 across 30 endpoint(s)):
HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA,
HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI,
HTTP-HEADER-PERMISSIONS_POLICY::T6_GITHUB_COM_WEBPWNIZED_MUTILL,
HTTP-HEADER-PERMISSIONS_POLICY::T7_GITHUB_COM_RAESENE_BWAPP,
HTTP-HEADER-PERMISSIONS_POLICY::T8_GITHUB_COM_OWASP_SECURITYSHE,
HTTP-HEADER-PERMISSIONS_POLICY::T9_GITHUB_COM_OWASP_NODEGOAT,
HTTP-HEADER-PERMISSIONS_POLICY::T10_GITHUB_COM_ADEYOSEMANPUTRA_P,
HTTP-HEADER-PERMISSIONS_POLICY::T11_GITHUB_COM_OWASP_RAILSGOAT
Header-Policy Evaluation: Present=['Content-Security-Policy', 'X-Frame-Options',
'X-Content-Type-Options', 'Referrer-Policy', 'Strict-Transport-Security'] |
Missing=['Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: bfc703fad0a6204cf818ee491980fba2ca3b3188cd4933baa907257b2de8761e (Artifact
#1859 | Unique Forensic Transcript)
```

## F-12: [portswigger.net:443] Missing HTTP Security Header(s): Referrer-Policy, Permissions-Policy (1 endpoint on origin) [portswigger.net:443 | LOW | Vuln CVSS: 3.2 | CONTROL_GAP_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00073 \| portswigger.net:443 \| Effective Origin: https://portswigger.net:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://portswigger.net:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: 3.2 \| Control Priority: 24.6/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 20% |
| **Proof Category & Admin Level** | CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Further manual or active exploitation was not executed outside approved ROE boundaries. |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-693 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 2 raw scanner observations merged (HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY, HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY) |
| **Technical Description** | [Target: https://portswigger.net/web-security] The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit. |
| **Targeted Specific Remediation** | Configure the specific missing HTTP response header(s) on origin https://portswigger.net:443: Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=(). |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1837/retest/execute on portswigger.net:443 (ASSET-00073) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-12 / HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY):**

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY | Consolidated
Root-Cause Group: 443:http-headers:security-header-policy-group:origin_portswigger_net_443
Immutable Provenance: Asset=ASSET-00073 | Effective Origin=https://portswigger.net:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.2 | Control Priority=24.6 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE | Merged Raw Observations (2 across 1 endpoint(s)):
HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY,
HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY
Header-Policy Evaluation: Present=['Content-Security-Policy', 'X-Frame-Options',
'X-Content-Type-Options', 'Strict-Transport-Security'] | Missing=['Referrer-Policy',
'Permissions-Policy'] | Compensating=[]
EvidenceCore SHA-256 Digest: d5d42761cd7f5e5265b04cee2fff3960abecec1c46e8e9c856e0f28e226e96e1 (Artifact
#1924 | Unique Forensic Transcript)
```

## F-13: [www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login [www.hackthissite.org:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00077 \| www.hackthissite.org:443 \| Effective Origin: https://www.hackthissite.org:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.hackthissite.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: N/A (Observation) \| Control Priority: 0.0/10 \| Recon Priority: 24.0/10 \| Exploitability Confidence: 5% |
| **Proof Category & Admin Level** | OBSERVATION_CONFIRMED :: PRE_AUTH_FORM_CSRF_OBSERVED \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Not proven by this check: authenticated state-changing Cross-Site Request Forgery (form is a pre-authentication login/search form). |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-352 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 2 raw scanner observations merged (ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG, ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG) |
| **Technical Description** | [Target: https://www.hackthissite.org/] WebPulse enumerated an HTML `<form method='POST' action='https://www.hackthissite.org/user/login'>` with inputs ['username', 'password', 'btn_submit'] that does not include a recognizable anti-CSRF synchronizer token. |
| **Targeted Specific Remediation** | Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1897/retest/execute on www.hackthissite.org:443 (ASSET-00077) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-13 / ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG):**

```
Finding Key: ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG  |  Consolidated Root-Cause Group:
443:web-app:html-form-missing-csrf-token:origin_www_hackthissite_org_443
Immutable Provenance: Asset=ASSET-00077 | Effective Origin=https://www.hackthissite.org:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=24.0 |
Exploitability Confidence=0.05
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (2 across 1 endpoint(s)):
ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG, ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG
EvidenceCore SHA-256 Digest: 4b234a1bb3e7f8fcc0cad879bd6c288a973404e59cc23425e9e8818539514ee1 (Artifact
#1984 | Unique Forensic Transcript)
```

## F-14: [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://portswigger.net/web-security/dashboard [portswigger.net:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00073 \| portswigger.net:443 \| Effective Origin: https://portswigger.net:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://portswigger.net:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: N/A (Observation) \| Control Priority: 0.0/10 \| Recon Priority: 22.7/10 \| Exploitability Confidence: 5% |
| **Proof Category & Admin Level** | OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED \| Admin Boundary Taxonomy: LEVEL_1_PUBLIC_PAGE_HTTP_200 |
| **Explicitly Not Proven (Boundary)** | Not proven by this check: administrative console exposure, privileged state actions, or authentication bypass (HTTP 200 on /dashboard or /admin path reflects public route or learning page reachability). |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-200 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 1 raw scanner observations merged (DAST-ADMIN-ACCESS-EP-02332) |
| **Technical Description** | Administrative boundary test `ADMIN-ACCESS-001` probed `https://portswigger.net/web-security/dashboard` and received `HTTP 200`. The candidate route (`/dashboard` or `/admin` path) returned HTTP 200 OK, but no administrative console controls, privileged state actions, or authentication bypass were verified (`LOGIN_INTERFACE_OR_ROUTE_DISCOVERED`). |

| | |
|---|---|
| **Targeted Specific Remediation** | Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS + MFA. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1914/retest/execute on portswigger.net:443 (ASSET-00073) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-14 / DAST-ADMIN-ACCESS-EP-02332):**

```
Finding Key: DAST-ADMIN-ACCESS-EP-02332  |  Consolidated Root-Cause Group:
443:phpmyadmin:phpmyadmin-admin-console-exposure:origin_portswigger_net_443
Immutable Provenance: Asset=ASSET-00073 | Effective Origin=https://portswigger.net:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=22.7 |
Exploitability Confidence=0.05
Admin Boundary Level: LEVEL_1_PUBLIC_PAGE_HTTP_200  |  Merged Raw Observations (1 across 1 endpoint(s)):
DAST-ADMIN-ACCESS-EP-02332
EvidenceCore SHA-256 Digest: 81b234c61b09a750a1dfcb35fdcb4a5f437b062fed4d94f7346016132d43a4c4 (Artifact
#2001 | Unique Forensic Transcript)
```

## F-15: [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://www.root-me.org/admin [www.root-me.org:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00078 | www.root-me.org:443 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.root-me.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: N/A (Observation) | Control Priority: 0.0/10 | Recon Priority: 22.7/10 | Exploitability Confidence: 5% |
| **Proof Category & Admin Level** | OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED | Admin Boundary Taxonomy: LEVEL_1_PUBLIC_PAGE_HTTP_200 |
| **Explicitly Not Proven (Boundary)** | Not proven by this check: administrative console exposure, privileged state actions, or authentication bypass (HTTP 200 on /dashboard or /admin path reflects public route or learning page reachability). |
| **CVE / CWE & Applicability Gate** | CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 1 raw scanner observations merged (DAST-ADMIN-ACCESS-EP-02464) |
| **Technical Description** | Administrative boundary test `ADMIN-ACCESS-001` probed `https://www.root-me.org/admin` and received `HTTP 200`. The candidate route (`/dashboard` or `/admin` path) returned HTTP 200 OK, but no administrative console controls, privileged state actions, or authentication bypass were verified (`LOGIN_INTERFACE_OR_ROUTE_DISCOVERED`). |
| **Targeted Specific Remediation** | Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS + MFA. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1915/retest/execute on www.root-me.org:443 (ASSET-00078) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-15 / DAST-ADMIN-ACCESS-EP-02464):**

```
Finding Key: DAST-ADMIN-ACCESS-EP-02464  |  Consolidated Root-Cause Group:
443:phpmyadmin:phpmyadmin-admin-console-exposure:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00078 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=22.7 |
Exploitability Confidence=0.05
Admin Boundary Level: LEVEL_1_PUBLIC_PAGE_HTTP_200  |  Merged Raw Observations (1 across 1 endpoint(s)):
DAST-ADMIN-ACCESS-EP-02464
EvidenceCore SHA-256 Digest: b684ff8111ad1b43586ed6cd87e0e2adb7989cf2dfe61d328061ef031662fa27 (Artifact
#2002 | Unique Forensic Transcript)
```

## F-16: [github.com:443] API Rate-Limiting Telemetry Headers Absent (Enforcement Untested - OWASP API4:2023) (7 endpoints on origin) [github.com:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00071 | github.com:443 | Effective Origin: https://github.com:443 (7 Affected Endpoint(s)) |

| | |
|---|---|
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://github.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: N/A (Observation) \| Control Priority: 0.0/10 \| Recon Priority: 17.8/10 \| Exploitability Confidence: 5% |
| **Proof Category & Admin Level** | OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Not proven by this check: absence of server-side/CDN rate limiting or susceptibility to volumetric brute-force (only response header telemetry absence was observed). |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-770 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |
| **Deduplicated Observations** | 7 raw scanner observations merged (API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI, API-RATE-LIMIT-HEADERS-MISSING::T24_GITHUB_COM_SNOOPYSECURITY_DV, API-RATE-LIMIT-HEADERS-MISSING::T25_GITHUB_COM_EREV0S_VAMPI, API-RATE-LIMIT-HEADERS-MISSING::T26_GITHUB_COM_INE_LABS_REST_API, API-RATE-LIMIT-HEADERS-MISSING::T28_GITHUB_COM_DOLEVF_BLACK_HAT_, API-RATE-LIMIT-HEADERS-MISSING::T29_GITHUB_COM_ROOTXJS_GRPC_GOAT, API-RATE-LIMIT-HEADERS-MISSING::T30_GITHUB_COM_INTERFERENCE_SECU) |
| **Technical Description** | [Target: https://github.com/OWASP/crAPI] Target https://github.com/OWASP/crAPI responded with HTTP 200 (text/html; charset=utf-8) without returning standard rate-limiting telemetry headers (`RateLimit-Limit` / `X-RateLimit-Limit`). Note (`RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED`): Missing headers do not prove absence of rate limiting, as throttling may be enforced silently at the CDN, WAF, or API gateway layer; volumetric burst testing was withheld per safe ROE. |
| **Targeted Specific Remediation** | Emit standardized RFC-draft RateLimit-* response headers on API endpoints and verify edge/gateway throttling thresholds. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1906/retest/execute on github.com:443 (ASSET-00071) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-16 / API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI):**

```
Finding Key: API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI  |  Consolidated Root-Cause
Group: 443:api-security:missing-rate-limit-headers:origin_github_com_443
Immutable Provenance: Asset=ASSET-00071 | Effective Origin=https://github.com:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=17.8 |
Exploitability Confidence=0.05
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (7 across 7 endpoint(s)):
API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI,
API-RATE-LIMIT-HEADERS-MISSING::T24_GITHUB_COM_SNOOPYSECURITY_DV,
API-RATE-LIMIT-HEADERS-MISSING::T25_GITHUB_COM_EREV0S_VAMPI,
API-RATE-LIMIT-HEADERS-MISSING::T26_GITHUB_COM_INE_LABS_REST_API,
API-RATE-LIMIT-HEADERS-MISSING::T28_GITHUB_COM_DOLEVF_BLACK_HAT_,
API-RATE-LIMIT-HEADERS-MISSING::T29_GITHUB_COM_ROOTXJS_GRPC_GOAT,
API-RATE-LIMIT-HEADERS-MISSING::T30_GITHUB_COM_INTERFERENCE_SECU
EvidenceCore SHA-256 Digest: 0ab33b173e365f5bf3b93b029fb573abdf9edfdbf1d004949c67df4a72766f09 (Artifact
#1993 | Unique Forensic Transcript)
```

## F-17: [API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Observed (/.within.website/x/cmd/anubis/api/honeypot/6dabeea5-bbe8-462f-8355-cdc93074954e/init) [www.root-me.org:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

| | |
|---|---|
| **Target Asset & Origin** | ASSET-00078 \| www.root-me.org:443 \| Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s)) |
| **Scope & Written Authorization** | IN_SCOPE \| Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.root-me.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.) |
| **4-Track Score Separation** | Vuln CVSS: N/A (Observation) \| Control Priority: 0.0/10 \| Recon Priority: 15.0/10 \| Exploitability Confidence: 5% |
| **Proof Category & Admin Level** | OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED \| Admin Boundary Taxonomy: NOT_ADMIN_ROUTE |
| **Explicitly Not Proven (Boundary)** | Not proven by this check: broken object/function authorization or unauthorized private data disclosure (route is an anti-bot challenge or public API endpoint). |
| **CVE / CWE & Applicability Gate** | CVE: N/A \| CWE: CWE-200 \| State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.) |

| | |
|---|---|
| **Deduplicated Observations** | 1 raw scanner observations merged (DAST-API-AUTHZ-EP-02459) |
| **Technical Description** | Targeted API authorization check `API-AUTHZ-001` issued an unauthenticated request to `https://www.root-me.org/.within.website/x/cmd/anubis/api/honeypot/6dabeea5-bbe8-462f-8355-cdc93074954e/init` and received `HTTP 200 OK` (8472 bytes). Route signature matches an anti-bot proof-of-work or honeypot challenge endpoint (`anubis` / `/.within.website/`); this is defensive bot-mitigation telemetry, not an unauthorized data disclosure vulnerability. |
| **Targeted Specific Remediation** | No remediation required for intentional anti-bot/honeypot challenge endpoints; verify WAF/bot-protection rules. |
| **Verification & Closure Rule** | Execute deterministic retest via POST /api/v1/findings/1913/retest/execute on www.root-me.org:443 (ASSET-00078) and confirm REMEDIATION_VERIFIED state in RTEX ledger. |

**Captured Technical Evidence (F-17 / DAST-API-AUTHZ-EP-02459):**

```
Finding Key: DAST-API-AUTHZ-EP-02459  |  Consolidated Root-Cause Group:
443:web-app:dast-api-authz-ep-02459:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00078 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=15.0 |
Exploitability Confidence=0.05
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (1 across 1 endpoint(s)):
DAST-API-AUTHZ-EP-02459
EvidenceCore SHA-256 Digest: 55da03f407c76d09b12f4503e7c16bc6e3d75b98251f25672debbb6e38d97814 (Artifact
#2000 | Unique Forensic Transcript)
```

## 3B. Consolidated Reconnaissance Surface & Scanner Health Telemetry

| ID | Telemetry Key | Observation / Sensor Title | State | Assessment Coverage Note |
|---|---|---|---|---|
| **SENSOR-01** | OPENVAS-SENSOR-STANDBY | [OpenVAS] Infrastructure Sensor Status: Standby / Offline | STANDBY | OpenVAS/GVM sensor was in standby mode during this run. Assessment coverage was fulfilled by Nmap v7.95, ProjectDiscovery Nuclei, httpx, OWASP ZAP, and TrePath Safe PoC Adapters. |

## 4. Evidence-Backed Attack Graph, Edge Provenance & Choke-Point Analysis

TrePath 2.5 Autonomous Scope Provenance, EVE, EvidenceCore & RTEX Engine AttackGraph 2.5 requires every attack-path edge to declare an explicit evidentiary state from the canonical 4-state model (OBSERVED, PRECONDITION_CONFIRMED, TECHNIQUE_VALIDATED, or INFERRED) and never chains unrelated services without shared credentials or pivot proof.

### 4.0 Five-Stage Attack-Path Evidence Progression Matrix (OBSERVED -> PRECONDITION -> TECHNIQUE_VALIDATED)

| Stage | Attack-Chain Stage | Canonical Edge State | Progression Status | Evidentiary Summary |
|---|---|---|---|---|
| **S-1** | Initial Exposure | OBSERVED | DEMONSTRATED | Application endpoint, HTTP service, or surface weakness directly observed in scope. |
| **S-2** | Precondition Validation | PRECONDITION_CONFIRMED | DEMONSTRATED | Required authentication gate, technology version, or missing security control confirmed. |
| **S-3** | Controlled Exploitation | INFERRED | REQUIRES_VALIDATION | Safe, non-destructive PoC adapter reproduces deterministic security behavior. |
| **S-4** | Privilege Boundary Assessment | INFERRED | REQUIRES_VALIDATION | Verifies whether obtained session or token crosses an authentication/authorization privilege boundary. |
| **S-5** | Impact Assessment | INFERRED | REQUIRES_VALIDATION | Documents demonstrated unauthorized access/data impact with sealed EvidenceCore transcripts (RTEX retests: 0). |

| Path ID | Stage | Finding Key | Edge Evidence State | Step Summary & Rationale | Remediation Chokepoint |
|---|---|---|---|---|---|

| Path ID | Stage | Finding Key | Edge Evidence State | Step Summary & Rationale | Remediation Chokepoint |
|---|---|---|---|---|---|
| **PATH-00023** | Step 1 (Cleartext HTTP Transport Observation) | TLS-COMPLIANT-CIPHER-TLS_AES_128_GCM_SHA256 | OBSERVED | Compliant TLS Encryption (TLSv1.3 / TLS_AES_128_GCM_SHA256) | Maintain current cryptographic configuration. |
| **PATH-00023** | Step 2 (Diagnostic / Authentication Precondition Exposure) | ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG | INFERRED | [www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login | Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies. |
| **PATH-00023** | Step 3 (Application / Session Policy Boundary Gap) | NMAP-NSE-80-HTTP-HEADERS | INFERRED | [Nmap NSE] http-headers on 80/TCP | Review Nmap NSE 'http-headers' output for port 80 and apply vendor security patches or configuration hardening. |
| **PATH-00023** | Step 4 (EVE_EXPLOIT_VALIDATION) | HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_ | OBSERVED | [OBSERVATION_CONFIRMED] Configuration/control gap confirmed at HTTP layer; no direct unauthorized data access or code execution resulted. | Define a restrictive CSP based on the application's required script, style, image and connection sources. |
| **PATH-00023** | Step 5 (EVE_EXPLOIT_VALIDATION) | ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG | OBSERVED | [EXPLOITATION_FAILED] Contextual inspection of https://www.hackthissite.org/ confirmed the form is an unauthenticated login/public form; authenticated state-changing CSRF exploitation is not applicable without an authenticated session action. | Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies. |

## 5. Stage 9 (9.1 - 9.7) Exploitation Validation & Post-Exploitation Matrix

Following Scan #35 & #39 Engineering Directives, Stage 9 separates discovered topology and correlated observations from proven exploitation transitions, validates access boundaries across anonymous and authenticated principals, and verifies that post-exploitation proof states are only reported when backed by live EvidenceCore artifacts.

### 5.1 Stage 9.3 & 9.4 Access Boundary & Post-Exploitation Verification Table

| Target Surface | Principal Tested | Verified Boundary State | Proven Capability | Explicitly Unproven Boundary | Artifact & Full SHA-256 |
|---|---|---|---|---|---|
| **phpMyAdmin Web Interface (/phpMyAdmin/)** | Unauthenticated HTTP Client | LOGIN_GATE_ENFORCED (Control Gap: Admin Login Exposed on Network) | HTTP 200 login page reachable over cleartext HTTP | Database administrative login and SQL table access are blocked by authentication gate (not proven) | #2001 (81b234c61b09a750a1dfcb35fdcb4a5f437b062fed4d94f7346016132d43a4c4) |

### 5.2 Stage 9.5 Lateral Movement Validation & Stage 9.6 CIA Impact Assessment

| Stage / Dimension | Validation Status | Demonstrated Evidence & Scope Boundary |
|---|---|---|
| **Stage 9.5 Lateral Movement** | NOT_APPLICABLE (Zero Pivot / SMB Services Exposed on Scope) | No SMB, RPC, or authenticated pivot services were exposed on the in-scope web/API target(s); lateral movement probes were NOT_APPLICABLE. |
| **Stage 9.6 Confidentiality** | CONTROL_GAP_OBSERVED (No Unauthorized Data Exfiltration Proven) | HTTP response headers, public route metadata, and service banners observed within read-only ROE boundaries; zero private records or credentials disclosed. |

| Stage / Dimension | Validation Status | Demonstrated Evidence & Scope Boundary |
|---|---|---|
| **Stage 9.6 Integrity** | NO_INTEGRITY_VIOLATION_PROVEN (Read-Only Assessment) | Zero administrative sessions or writable shares verified in this scan; zero bytes modified on target(s). |
| **Stage 9.6 Availability** | NOT_TESTED (Out of Scope per Non-Destructive ROE) | Zero service disruption; all probes completed within deterministic rate limits. |

## 5B. Exploit Validation Engine (EVE) - Controlled Exploitation Lifecycle & Decisions

TrePath 2.3 Exploit Validation Engine (EVE) bridges vulnerability discovery and remediation by evaluating preconditions, enforcing operator HMAC approval, executing deterministic read-only validation adapters (EVE-AUTH-001, EVE-AUTHZ-001, EVE-INJ-001, EVE-FILE-001, EVE-NET-001), and distinguishing Vulnerability Detected, Exploitability Validated, Impact Verified, and Remediation Verified.

| 4-Tier Platform Distinction | Canonical Tier Code | Validated Job Count | Evidentiary Standard |
|---|---|---|---|
| **1. Vulnerability Detected** | VULNERABILITY_DETECTED | 17 | Scanner or passive control observation confirmed in scope. |
| **2. Exploitability Validated** | EXPLOITABILITY_VALIDATED | 0 | Preconditions satisfied and deterministic test reproduced behavior. |
| **3. Impact Verified** | **IMPACT_VERIFIED** | 0 | Controlled test established unauthorized access, privilege escalation, or data exposure. |
| **4. Remediation Verified** | REMEDIATION_VERIFIED | 0 | Subsequent RTEX retest proved the security boundary now holds. |

### 5B.1 Executed EVE Validation Jobs & Sealed Evidence Decisions

| EVE Job Key | Finding (Asset) | Adapter | Validated Outcome | Platform Tier | Decision | Full EvidenceCore SHA-256 |
|---|---|---|---|---|---|---|
| **EVE-JOB-00086-S44-F1758** | #1758 (ASSET-00070) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | 2c111cdc3c56e340515331dab657f9ec5fea61df132bb961a9060995849ddfd3 |
| **EVE-JOB-00087-S44-F1792** | #1792 (ASSET-00072) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | 276f4d07f06f18945b7ea9353e660f21ec4c2f5c8dc309ae8df5899cee255848 |
| **EVE-JOB-00088-S44-F1839** | #1839 (ASSET-00074) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | 7be4e45cee7889484c4ff3c41b8256745c7f04658235122657fbe6c184b348c4 |
| **EVE-JOB-00089-S44-F1844** | #1844 (ASSET-00075) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | 546a26977fab7387950092f6d82cff1bbea7bb84ac58e3a29281a86117b4a176 |
| **EVE-JOB-00090-S44-F1846** | #1846 (ASSET-00076) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | 0c295a5d24505a98867863a4c9809ccb100f36da770ae1ad7d557ef485f94a2a |
| **EVE-JOB-00091-S44-F1855** | #1855 (ASSET-00078) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | 6e33a7e0253e3555d93321eb11fc6600544ccb40ea55198ea70efcee70b2e760 |
| **EVE-JOB-00092-S44-F1857** | #1857 (ASSET-00079) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | abc3361c10ca72ee4a8b50a4a091c31311c92f3778163adb323d924928b25dfb |
| **EVE-JOB-00093-S44-F1861** | #1861 (ASSET-00080) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | 3251e08276e88ba5b8972e466406c87a38e762b0c611b87dbdf244f4061d61cb |
| **EVE-JOB-00094-S44-F1867** | #1867 (ASSET-00081) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | 5971cd590f81113b277bff58850be61f07596c1bcbf8d90cec457ceba6d89652 |
| **EVE-JOB-00095-S44-F1879** | #1879 (ASSET-00083) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | d61647e948b2101fef4710b92af00e22c1e0086bcc1ec4e70010e9f226a57c04 |

| EVE Job Key | Finding (Asset) | Adapter | Validated Outcome | Platform Tier | Decision | Full EvidenceCore SHA-256 |
|---|---|---|---|---|---|---|
| **EVE-JOB-00096-S44-F1764** | #1764 (ASSET-00071) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | 92835904b403461f2016a14bf67b87d83694dc1325da130dc9f8f54d00bc890c |
| **EVE-JOB-00097-S44-F1836** | #1836 (ASSET-00073) | EVE-TLS-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | b3188cdf138d9607501edf6172051c288313f36e18b829cd2c282dbd5ca9b666 |
| **EVE-JOB-00098-S44-F1896** | #1896 (ASSET-00077) | EVE-CSRF-001 | EXPLOITATION_FAILED | VULNERABILITY_DETECTED | REJECTED | 864c16e19b820d58304fcda52a597a5f71316fc621f312474ea4408141193a3d |
| **EVE-JOB-00099-S44-F1914** | #1914 (ASSET-00073) | EVE-AUTH-001 | EXPLOITATION_FAILED | VULNERABILITY_DETECTED | REJECTED | c72081a6eb671e1014212ecd5ea2a36e6857796d153a3a389b53fcf53c2d9d50 |
| **EVE-JOB-00100-S44-F1915** | #1915 (ASSET-00078) | EVE-AUTH-001 | EXPLOITATION_FAILED | VULNERABILITY_DETECTED | REJECTED | 9163a73798a3adcc43320f22923d3458cb65927c70dd648c1ec9841cac08066a |
| **EVE-JOB-00101-S44-F1906** | #1906 (ASSET-00071) | EVE-API-001 | OBSERVATION_CONFIRMED | VULNERABILITY_DETECTED | CONFIRMED | df9036cfe2cf6968bc73ff6ada7d398cb1abfe7ebe3283b3a81b52018ab1bfc3 |
| **EVE-JOB-00102-S44-F1913** | #1913 (ASSET-00078) | EVE-AUTHZ-001 | EXPLOITATION_FAILED | VULNERABILITY_DETECTED | REJECTED | 7e8ae5ed61edadd3971b5d6e935de58ac6460350412a906f79bc92e0fc76007a |

## 6. Four-Tier Evidence-Driven Compliance Control Mapping

| Primary Finding | PCI-DSS v4.0 | NIST SP 800-53 Rev 5 | ISO/IEC 27001:2022 | CIS Controls v8 |
|---|---|---|---|---|
| **HTTP Security Header Policy (CSP/HSTS)** | Req 6.4.1 / 6.4.2 | SC-8 / SI-10 | A.8.26 / A.8.28 | Control 16.11 |
| **TOMCAT-MGR-001 (Admin Console Auth)** | Req 2.2.2 / 8.2.1 | IA-5 / AC-6 | A.5.17 / A.8.2 | Control 4.7 / 5.2 |
| **SMB-LIST-001 (Samba Anonymous Enum)** | Req 1.3.1 / 2.2.4 | AC-3 / SC-7 | A.8.20 / A.8.3 | Control 3.3 / 4.1 |
| **PHPINFO-001 & Legacy Service Hygiene** | Req 2.2.6 / 6.3.3 | CM-6 / SI-2 | A.8.8 / A.8.9 | Control 4.1 / 7.1 |

## 7. ENUMCORE 6-Stage CVE Applicability Validation & Threat Intelligence

| CVE / CWE | Validation State | Preconditions Verified | CVSS | EPSS | CISA KEV | Applicability & Precondition Note |
|---|---|---|---|---|---|---|
| **CWE-693** | VERSION_DETECTED | No (Banner Only) | 5.5 | 8.0% | No | No CVE identifier associated; scored by CWE control category. |

## 8. Prioritized Remediation Roadmap & 7-Step RTEX Verification Ledger (Stage 8)

| Task ID | Origin Host:Port (Asset) | Priority | Status | Work Package Title | Origin-Accurate Fix Guidance | Verification & Closure Rule |
|---|---|---|---|---|---|---|
| **REM-00203** | owasp.org:443 (ASSET-00070) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_: [owasp.org:443] | Configure the specific missing HTTP response header(s) on origin https://owasp.org:443: Content-Security-Policy: default-src 'self'; fr | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_ |
| **REM-00204** | google-gruyere.appspot.com:443 (ASSET-00072) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM: [google-gruyere. | Configure the specific missing HTTP response header(s) on origin https://google-gruyere.appspot.com:443: Content-Security-Policy: defau | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM o |

| Task ID | Origin Host:Port (Asset) | Priority | Status | Work Package Title | Origin-Accurate Fix Guidance | Verification & Closure Rule |
|---|---|---|---|---|---|---|
| **REM-00205** | pentesterlab.com:443 (ASSET-00074) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM: [pentesterlab.com:443] Mis | Configure the specific missing HTTP response header(s) on origin https://pentesterlab.com:443: Content-Security-Policy: default-src 'se | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM on penteste |
| **REM-00206** | www.hackthebox.com:443 (ASSET-00075) | P2-Planned | open | Remediate HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM: [www.hackthebox.com:443] Missing | Configure the specific missing HTTP response header(s) on origin https://www.hackthebox.com:443: X-Frame-Options: DENY (or verify CSP f | Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM on www.hackthebox |
| **REM-00207** | tryhackme.com:443 (ASSET-00076) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM: [tryhackme.com:443] Missing H | Configure the specific missing HTTP response header(s) on origin https://tryhackme.com:443: Content-Security-Policy: default-src 'self' | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM on tryhackme.c |
| **REM-00208** | www.root-me.org:443 (ASSET-00078) | P2-Planned | open | Remediate HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG: [www.root-me.org:443] Missing HTTP | Configure the specific missing HTTP response header(s) on origin https://www.root-me.org:443: X-Frame-Options: DENY (or verify CSP fram | Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG on www.root-me.org:4 |
| **REM-00209** | www.hackinghub.io:443 (ASSET-00079) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO: [www.hackinghub.io:443] M | Configure the specific missing HTTP response header(s) on origin https://www.hackinghub.io:443: Content-Security-Policy: default-src 's | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO on www.hac |
| **REM-00210** | pentest-ground.com:443 (ASSET-00080) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM: [pentest-ground.com:443] | Configure the specific missing HTTP response header(s) on origin https://pentest-ground.com:443: Content-Security-Policy: default-src ' | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM on pentes |
| **REM-00211** | genai.owasp.org:443 (ASSET-00081) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG: [genai.owasp.org:443] Missi | Configure the specific missing HTTP response header(s) on origin https://genai.owasp.org:443: Content-Security-Policy: default-src 'sel | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG on genai.owa |
| **REM-00212** | vwad.owasp.org:443 (ASSET-00083) | P2-Planned | open | Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG: [vwad.owasp.org:443] Missing | Configure the specific missing HTTP response header(s) on origin https://vwad.owasp.org:443: Content-Security-Policy: default-src 'self | Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG on vwad.owasp |
| **REM-00213** | github.com:443 (ASSET-00071) | P3-Backlog | open | Remediate HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA: [github.com:443] Missin | Configure the specific missing HTTP response header(s) on origin https://github.com:443: Permissions-Policy: geolocation=(), microphone | Verification Test: TrePath Retest Adapter for HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA on githu |
| **REM-00214** | portswigger.net:443 (ASSET-00073) | P3-Backlog | open | Remediate HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY: [portswigger.net:443] | Configure the specific missing HTTP response header(s) on origin https://portswigger.net:443: Referrer-Policy: strict-origin-when-cross | Verification Test: TrePath Retest Adapter for HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY on port |

| Task ID | Origin Host:Port (Asset) | Priority | Status | Work Package Title | Origin-Accurate Fix Guidance | Verification & Closure Rule |
|---|---|---|---|---|---|---|
| **REM-00215** | www.hackthissite.org:443 (ASSET-00077) | P3-Backlog | open | Remediate ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG: [www.hackthissite.org] [WebPulse] HTML | Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies. [Affected Asse | Verification Test: TrePath Retest Adapter for ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG on www.hackthissite.org: |
| **REM-00216** | portswigger.net:443 (ASSET-00073) | P3-Backlog | open | Remediate DAST-ADMIN-ACCESS-EP-02332: [ADMIN-ACCESS-001] Candidate Route or Login Interface Dis | Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS | Verification Test: TrePath Retest Adapter for DAST-ADMIN-ACCESS-EP-02332 on portswigger.net:443 (ASSET-00073) \| Clo |
| **REM-00217** | www.root-me.org:443 (ASSET-00078) | P3-Backlog | open | Remediate DAST-ADMIN-ACCESS-EP-02464: [ADMIN-ACCESS-001] Candidate Route or Login Interface Dis | Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS | Verification Test: TrePath Retest Adapter for DAST-ADMIN-ACCESS-EP-02464 on www.root-me.org:443 (ASSET-00078) \| Clo |
| **REM-00218** | github.com:443 (ASSET-00071) | P3-Backlog | open | Remediate API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI: [github.com:443] API Rate- | Emit standardized RFC-draft RateLimit-* response headers on API endpoints and verify edge/gateway throttling thresholds. [Affected Asse | Verification Test: TrePath Retest Adapter for API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI on github.c |
| **REM-00219** | www.root-me.org:443 (ASSET-00078) | P3-Backlog | open | Remediate DAST-API-AUTHZ-EP-02459: [API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Obse | No remediation required for intentional anti-bot/honeypot challenge endpoints; verify WAF/bot-protection rules. [Affected Asset: www.ro | Verification Test: TrePath Retest Adapter for DAST-API-AUTHZ-EP-02459 on www.root-me.org:443 (ASSET-00078) \| Closur |

## 8.1A Seven-Step Remediation & Retest Verification Loop (RTEX Lifecycle)

| Step | RTEX Lifecycle Stage | Current Status | Verification & EvidenceCore Protocol |
|---|---|---|---|
| **Step 1** | Baseline Finding Sealed (T0) | COMPLETED | 17 consolidated findings sealed with 9-field provenance & 64-hex SHA-256. |
| **Step 2** | Remediation Assigned (REM-xxxxx) | COMPLETED | 17 origin-bound RemediationTask work packages generated. |
| **Step 3** | Deterministic Retest Executed | STANDBY_AWAITING_FIX | 0 live retest execution(s) recorded via POST /api/v1/findings/{id}/retest/execute. |
| **Step 4** | Negative-Control Validation | READY | Verifies response is not a generic WAF block, anti-bot challenge, or out-of-scope redirect. |
| **Step 5** | EvidenceCore Retest Sealing | READY | Before/after HTTP or TCP transcript sealed with fresh FIPS 180-4 SHA-256 digest. |
| **Step 6** | Closure Decision (REMEDIATION_VERIFIED) | PENDING_CLOSURE | Promotes Finding to REMEDIATION_VERIFIED only when deterministic control check passes. |
| **Step 7** | T1 Post-Retest Risk Recalculation | HYPOTHETICAL_FORECAST_ONLY | Recalculates live T1 risk index; until retest executes, 2.1/10 remains labeled HYPOTHETICAL_PROJECTION. |

## 8.2 Deterministic Retest Execution Ledger (RTEX-xxxxx)

| Retest Key | Target Finding | Execution Status | Resulting Proof State | Evidence Artifact | Verification Notes |
|---|---|---|---|---|---|
| **RTEX-STANDBY** | All Open Findings | AWAITING_PATCH | PENDING_RETEST | EvidenceCore Ready | Use POST /api/v1/findings/{id}/retest/execute after applying remediation to record cryptographic closure proof. |

# 9. EvidenceCore Cryptographic Integrity, RFC 8032 Ed25519 Signature Bundle & Quality Gates

## 9.0 Verifiable RFC 8032 Ed25519 Signature, UTC Timestamp Reconciliation & Key Discovery

| | |
|---|---|
| **Signing Algorithm & Authority** | Ed25519 (RFC 8032) + SHA-256 (FIPS 180-4) \| Signer: TrePath-EvidenceCore-Authority-v2.5 |
| **Reconciled UTC Timestamps** | Scan Started: 2026-11-02T14:59:54Z \| Scan Completed: 2026-11-02T15:01:39Z \| Report Generated & Signed: 2026-11-02T16:19:58Z (Drift: 0s) |
| **Trusted Public-Key Discovery** | Well-Known URI: /.well-known/trepath-evidencecore-pubkey.json \| Verify Endpoint: /api/v1/unified/verify-signature |
| **Canonical Manifest SHA-256** | fc5b9642d6b726b2a46570c1300f5d60b4a6ffc950105fd5d363796b2c6d74ac |
| **Ed25519 Signature (128-Hex)** | 09b70a20bc11db71790b14f4bfe9a0dc28665704a40f37d2d6f1593065718bae63e9f64a8811e209a40835f62a38dd55c9de743ed48a251bc6a85639f531fb0c |
| **Ed25519 Signature (Base64)** | CbcKILwR23F5CxT0v+mg3ChmVwSkDzfS1vFZMGVxi65j6fZKiBHiCaQINfYqON1Vyd50PtSKJRvGqFY59TH7DA== |
| **Public Key Fingerprint SHA-256** | bc91f1e0b7c69696547e1efa0f05a7f9c1a201abf0cf80dabf698e43624c7eb1 |
| **Public Key (Raw Hex / PEM)** | Hex: 61e14ce688b5c816bcc76b30bcc93c9c2914fa085a2ff326594cd1c5565f05b9 \| PEM: -----BEGIN PUBLIC KEY----- MCowBQYDK2VwAyEAYeFM5oi1yBa8x2swvMk8nCkU+ghaL/MmWUzRxVZfBbk= -----END PUBLIC KEY----- |
| **Signature Verification Result** | VERIFIED_AUTHENTIC (Bound Artifacts: 197) |
| **Live Tamper-Detection Self-Test** | PASSED (Tampered Manifest Deterministically Rejected) - 1-bit payload mutation + 1-byte signature mutation deterministically rejected by Ed25519 verifier. |

## 9.1 Automated Acceptance & Negative Quality Gates (AT-01..AT-10 + NG-01..NG-06)

| Gate ID | Verification Domain | Dynamic Acceptance & Negative Quality Gate Rule | Status |
|---|---|---|---|
| **AT-01/02** | Scope & Redirect Provenance | 7-stage scope funnel reconciled (46 requested -> 14 origin assets); external links isolated. | **PASSED** |
| **AT-03..06** | Proof-State Reconciliation | **Executive, Section 1.2 & Stage 9 agree: CONFIRMED_ADMIN_AUTH=0, IMPACT_VERIFIED=0.** | **PASSED** |
| **AT-07/08** | Risk & Port Reconciliation | 4-State port discovery reconciled (0 TCP ports, 376 HTTP endpoints); 7 risk dimensions sum (41.1/100) matches headline (41.1/100). | **PASSED** |
| **AT-09/10** | Origin Consolidation & Ed25519 | 180 raw observations -> 17 unique findings; Consistency=100.0%, Ed25519=VERIFIED_AUTHENTIC. | **PASSED** |
| **NG-01** | No Admin Exposure Claim from Route Rea | Candidate /dashboard or /admin HTTP 200 routes without verified admin console controls classified as OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED (Low). | **PASSED** |
| **NG-02** | No Outdated Software Claim for Current | Modern versions (e.g. nginx 1.31.8) marked is_outdated=False; banner-only fingerprints use OBSERVATION_CONFIRMED :: VERSION_FINGERPRINT_BANNER_ONLY. | **PASSED** |
| **NG-03** | No API Vulnerability Claim from Anti-B | Anubis / /.within.website/ honeypot and public API routes classified as OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED (Low). | **PASSED** |
| **NG-04** | No Rate-Limit Absence Claim from Missi | Absent X-RateLimit-* headers classified as OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED (Low). | **PASSED** |
| **NG-05** | Zero Cross-Asset Contamination in Reme | All 17 RemediationTask rows bound to exact finding asset_id and effective_origin host:port. | **PASSED** |
| **NG-06** | No Unverified Post-Remediation Risk Cl | Executed retests = 0; post-hardening 2.1/10 explicitly labeled HYPOTHETICAL_PROJECTION. | **PASSED** |

# 10. Unified Security Platform Integration (XTRIKE SAST + TrePath 2.5 Autonomous Scope Provenanc

## 10.0 Unified Finding Registry (Code Source-to-Sink -> Runtime Verification -> RTEX -> Noctis)

| Unified ID | Finding (Asset) | XTRIKE SAST Code Location | Expedite Strike / EVE State | 4-Track Score Summary | Noctis Posture State |
|---|---|---|---|---|---|
| **UFR-044-001** | F-01 (ASSET-00070) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:5.5 \| Ctrl:40.7 | ACTIVE_TELEMETRY_WATCH |

| Unified ID | Finding (Asset) | XTRIKE SAST Code Location | Expedite Strike / EVE State | 4-Track Score Summary | Noctis Posture State |
|---|---|---|---|---|---|
| **UFR-044-002** | F-02 (ASSET-00072) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:5.5 \| Ctrl:40.7 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-003** | F-03 (ASSET-00076) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:5.5 \| Ctrl:40.7 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-004** | F-04 (ASSET-00079) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:5.5 \| Ctrl:40.7 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-005** | F-05 (ASSET-00080) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:5.5 \| Ctrl:40.7 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-006** | F-06 (ASSET-00081) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:5.5 \| Ctrl:40.7 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-007** | F-07 (ASSET-00083) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:5.5 \| Ctrl:40.7 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-008** | F-08 (ASSET-00071) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:3.2 \| Ctrl:24.6 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-009** | F-09 (ASSET-00073) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:3.2 \| Ctrl:24.6 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-010** | F-10 (ASSET-00074) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:3.2 \| Ctrl:24.6 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-011** | F-11 (ASSET-00075) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:3.2 \| Ctrl:24.6 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-012** | F-12 (ASSET-00078) | server.ts:118 | CONTROL_GAP_CONFIRMED | CVSS:3.2 \| Ctrl:24.6 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-013** | F-13 (ASSET-00077) | External Surface (DAST) | OBSERVATION_CONFIRMED | CVSS:N/A (Observation) \| Ctrl:0.0 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-014** | F-14 (ASSET-00073) | External Surface (DAST) | OBSERVATION_CONFIRMED | CVSS:N/A (Observation) \| Ctrl:0.0 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-015** | F-15 (ASSET-00078) | External Surface (DAST) | OBSERVATION_CONFIRMED | CVSS:N/A (Observation) \| Ctrl:0.0 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-016** | F-16 (ASSET-00071) | server.ts:118 | OBSERVATION_CONFIRMED | CVSS:N/A (Observation) \| Ctrl:0.0 | ACTIVE_TELEMETRY_WATCH |
| **UFR-044-017** | F-17 (ASSET-00078) | External Surface (DAST) | OBSERVATION_CONFIRMED | CVSS:N/A (Observation) \| Ctrl:0.0 | ACTIVE_TELEMETRY_WATCH |

### 10.1 Autonomous 9-Stage Orchestration Architecture & Centralized Version Manifest

| Stage | Engine Module (Version) | Execution Outcome |
|---|---|---|
| **Stage 1-2** | Scope & WebPulse 2.5 | Verified 14 in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)), 0 open TCP ports, and 376 HTTP endpoints. |
| **Stage 3** | ENUMCORE 2.5 | Mapped CPEs and separated precondition-verified KEVs from banner-only candidates. |
| **Stage 4-5** | HeaderPolicyEvaluator 2.5 & EVE 2.5 | Enforced RoE scope lock & read-only HTTP DAST checks (0 destructive or out-of-scope PoCs executed). |
| **Stage 6-7** | Expedite Strike 2.5 & AttackGraph 2.5 | Assigned 4-level admin boundary taxonomy and built per-edge evidence-backed attack chains. |
| **Stage 8-9** | RiskEngine 2.5, RTEX 2.5 & Noctis 2.5 | Computed 7-dimension risk (T0=4.1/10, T1=4.1/10) and signed RFC 8032 Ed25519 manifest. |

## 11. Sign-Off & Deliverables Attestation (TrePath 2.5 Autonomous Scope Provenance, EVE, EvidenceC

| Role | Attestation Statement | Signature / Timestamp |
|---|---|---|
| **Lead Penetration Tester** | All findings, origins, and PoC transcripts verified against EvidenceCore SHA-256 & Ed25519 seals. | SIGNED \| 2026-11-02 16:19:58 UTC |
| **Principal Security Architect** | TrePath 2.5 Autonomous Scope Provenance, EVE, EvidenceCore & RTEX Engine (TP25-BUILD-20261102-UNIFIED) AT-01..AT-10, NG-01..NG-06 & 26/26 Quality Gates passed. | VERIFIED \| 2026-11-02 16:19:58 UTC |
| **Client System Owner** | Acknowledges receipt of prioritized remediation roadmap and RTEX retest workflow. | _____ |